INCIDENT REPORT

SSH Brute-Force, Database Exfiltration & Evidence Deletion

novameddb — ramyasoc-virtual-machine

Incident Reference	IR-2026-0328-001
Date of Incident	28 March 2026
Classification	**CONFIDENTIAL — RESTRICTED**
Severity	**CRITICAL**
Affected System	ramyasoc-virtual-machine (Ubuntu 22.04.5 LTS)
Attacker IP	**192.168.110.145 (Kali Linux)**

Report Prepared By

Name	Ramya Radjesh
Role	SOC Analysts | ubuntu1-server
Project info	https://github.com/ramyaradjesh/Wazuh-Threat-detection-Project
Analyst - Portfolio	https://ramyaradjesh.github.io

Contents

1. Executive Summary 3
2. Scenario Background 4
   2.1 Organisation Profile 4
   2.2 Security Posture at Time of Incident 4
   2.3 Threat Actor Profile 4
3. Incident Metadata 5
4. Wazuh Alert Log 5
   Alert 1 — SSH PAM Login Failure (Rule 5503) 6
   Alert 2 — SSH Authentication Failure with Lateral Movement (Rule 5760) 6
   Alert 3 — SSH Authentication Success (Rule 5715) 7
   Alert 4 — PAM Login Session Opened (Rule 5501) 7
5. Detailed Post-Access Activity 8
   5.1 Initial Access — SSH from Kali Linux 8
   5.2 Data Exfiltration — mysqldump 8
   5.3 Privilege Escalation 9
   5.4 Evidence Deletion — Anti-Forensics 9
6. Attack Timeline 10
7. MITRE ATT&CK Mapping 10
8. Impact Assessment 11
   8.1 Patient Data (PHI) 11
   8.2 Staff Credentials 11
   8.3 Regulatory Exposure 11
9. Recommendations 12
   Immediate (Within 24 Hours) 12
10. Conclusion 12
Appendix — Attacker-Submitted Proof of Exploit 13
References 14

1. Executive Summary

NovaMed Diagnostics Pvt. Ltd. is a mid-size healthcare diagnostics firm operating out of Pondicherry. Their internal Ubuntu server — ramyasoc-virtual-machine — serves a dual purpose: it is both a general-purpose employee workstation and the host for the company's patient records and billing database, novameddb, running on MariaDB 10.6.23.

The root MySQL account retained a weak password, and a secondary account, **dbbackup**, had been inadvertently granted excessive privileges. SSH remained open to the entire internal network with password-based authentication enabled.

On 28 March 2026, an attacker operating from a Kali Linux machine at IP 192.168.110.145 exploited this neglect. They brute-forced their way into the ramyasoc user account over SSH, dumped the entire novameddb database to a local file using mysqldump, verified the contents, escalated to root via sudo -i, and then deleted the dump file to cover their tracks — all within approximately two minutes.

Two tables were fully exfiltrated: **patients** — containing names, dates of birth, diagnoses, and insurance IDs for 35+ individuals — and **staff_credentials** — containing usernames, bcrypt-hashed passwords, roles, salary figures, and hospital IDs for all 13 staff members. This constitutes a **critical data breach** of Protected Health Information (PHI) and personally identifiable information (PII), with potential exposure under HIPAA, GDPR, and PCI-DSS.

2. Scenario Background

2.1 Organisation Profile

NovaMed Diagnostics Pvt. Ltd. is a mid-size healthcare diagnostics company. Their internal server (ramyasoc-virtual-machine) runs Ubuntu 22.04.5 LTS and hosts both the company's day-to-day operations and the novameddb patient and billing database on MariaDB 10.6.23. The Wazuh agent (agent ID 001) reports to the manager ubuntu1-server, which feeds alerts to the SOC.

2.2 Security Posture at Time of Incident

At the time of the attack, the following misconfigurations were present on the affected host:

- The server had not received security patches in approximately 3 months following the reassignment of the database administrator, Arvind.
- SSH password-based authentication was enabled and accessible from anywhere on the internal network — no IP restriction was in place.
- The ramyasoc OS account held unrestricted sudo access, meaning any successful SSH login immediately granted a path to root.
- The novameddb MySQL root account used a weak, easily guessable password, and the dbbackup account had been inadvertently granted excessive privileges.
- No database activity monitoring was configured. A full mysqldump could be executed without any alert being raised at the DB layer.

2.3 Threat Actor Profile

The attacker operated from a Kali Linux machine at **192.168.110.145** — an IP within the internal network, suggesting either a malicious insider or an attacker who had already established a foothold on an internal device. The precision and speed of the operation — moving directly from SSH access to database dump to file deletion within two minutes — indicates prior familiarity with the target environment. This is consistent with the **insider-assisted threat model**: someone who knew the server's role, the database name, and the location of the data.

3. Incident Metadata

Incident ID	IR-2026-0328-001
Date Detected	28 March 2026
Time Window	13:18:17 UTC — 13:19:02 UTC (approx. 45 seconds of active intrusion)
Detection Source	Wazuh SIEM / sshd logs via ubuntu1-server agent
Target Host	ramyasoc-virtual-machine (192.168.110.143)
Target OS	Ubuntu 22.04.5 LTS (GNU/Linux 6.8.0-106-generic x86_64)
Target Database	novameddb (MariaDB 10.6.23)
Attacker IP	**192.168.110.145**
Attacker Platform	**Kali Linux**
Entry Point	**SSH (port 22) — brute-force into ramyasoc account**
Data Compromised	**patients table + staff_credentials table (full dump)**
Evidence Deleted	**Yes — /tmp/patients_bigdump.csv removed by attacker**
MITRE ATT&CK Coverage	T1110.001, T1110, T1078, T1021, T1005, T1070.004

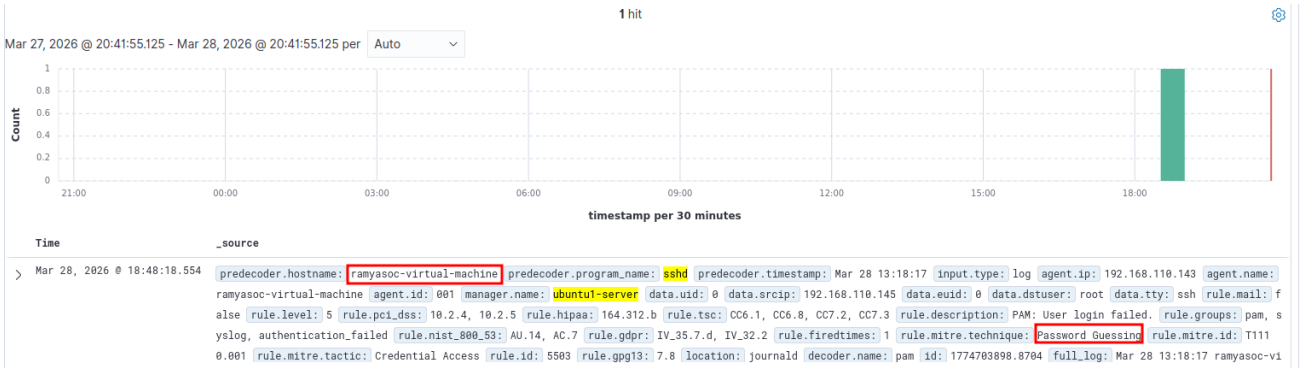
4. Wazuh Alert Log

The following four alerts were generated by Wazuh during the intrusion window. They are presented in chronological order and represent the detection trail from initial probe through to confirmed access.

#	Alert Name	Time	Rule ID	Severity	MITRE Tactic
1	SSH PAM Login Failure	13:18:17 UTC	5503	**MEDIUM**	Credential Access
2	SSH Authentication Failure	13:18:42 UTC	5760	**MEDIUM**	Credential Access, Lateral Movement
3	SSH Authentication Success	13:19:02 UTC	5715	**HIGH**	Persistence, Privilege Escalation, Initial Access, Lateral Movement
4	PAM Login Session Opened	13:19:02 UTC	5501	**HIGH**	Defense Evasion, Persistence, Initial Access

Alert 1 — SSH PAM Login Failure (Rule 5503)

The first alert fired at 13:18:17 UTC when Wazuh detected a PAM authentication failure via sshd. The source IP 192.168.110.145 attempted to log in as root but was denied. Rule 5503 fired at level 5, mapped to MITRE technique T1110.001 **(Password Guessing)** under the Credential Access tactic. This was the opening move of the brute-force sequence.



Alert 2 — SSH Authentication Failure with Lateral Movement (Rule 5760)

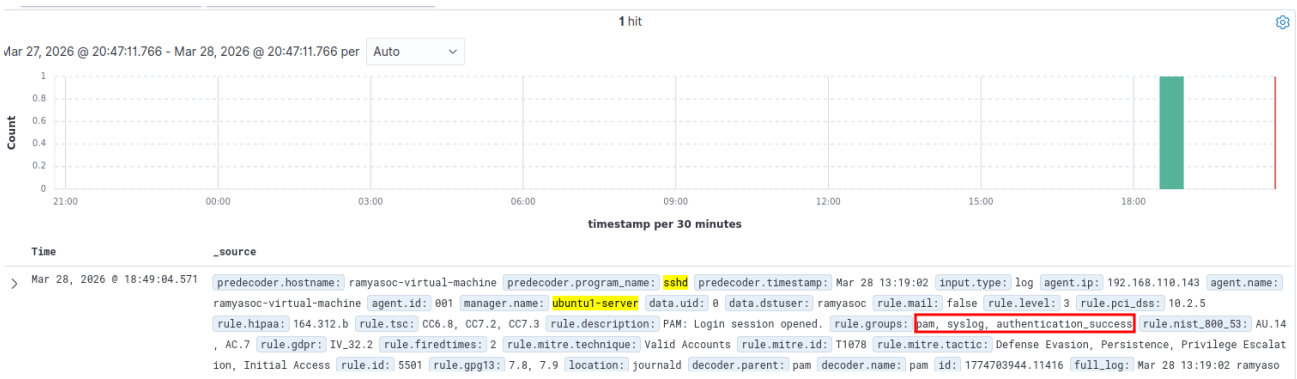
Twenty-five seconds later at 13:18:42 UTC, a second authentication failure was recorded from the same source IP, this time through a new source port (49044). The rule description reads **'sshd: authentication failed'**. Notably, Wazuh now mapped this event to two MITRE tactics: Credential Access and, for the first time, Lateral Movement. Rule 5760 also recorded firedtimes: 2, confirming this is part of a repeated pattern rather than a one-off event. The attacker is still probing.

Alert 3 — SSH Authentication Success (Rule 5715)

At 13:19:02 UTC — exactly 20 seconds after the second failure — the third alert fired: 'sshd: authentication success'. The attacker had **successfully logged in**, this time as ramyasoc rather than root, from source port 45574. Rule 5715 is level 3, but the MITRE coverage it triggered is significant: T1078 (Valid Accounts) and T1021 (Remote Services), with tactics spanning Defense Evasion, Persistence, Privilege Escalation, Initial Access, and Lateral Movement. This alert marks the transition from reconnaissance to active intrusion.

Alert 4 — PAM Login Session Opened (Rule 5501)

Fired at the same second as Alert 3 (13:19:02 UTC), this alert confirmed that PAM had opened a login session for the ramyasoc account. Rule 5501, level 3. The description reads **'PAM: Login session opened'**. This is the system formally acknowledging the attacker's presence — an interactive shell was now active. From this point on, the attacker had a working terminal on the victim machine.



5. Detailed Post-Access Activity

What follows is a step-by-step reconstruction of everything the attacker did after gaining access, based on terminal screenshots captured during the investigation. The activity is divided into three distinct phases: **initial access and reconnaissance**, **data exfiltration**, and **evidence deletion**.

5.1 Initial Access — SSH from Kali Linux

The attacker's Kali Linux terminal shows the moment of entry. The command issued was:

```
ssh ramyasoc@<target-IP>
```

The system responded with the standard Ubuntu 22.04.5 LTS welcome banner, confirming a successful shell. This is the session that Wazuh captured in Alerts 3 and 4. The attacker now had an interactive prompt on the victim machine as the **ramyasoc** user.

5.2 Data Exfiltration — mysqldump

From within the ramyasoc shell, the attacker ran the following command:

```
mysqldump -u root -p novameddb > /tmp/patients_bigdump.csv
```

This command connected to the **novameddb** MariaDB instance using the **root** database account, dumped the entire database, and wrote the output to `/tmp/patients_bigdump.csv`. The fact that the attacker used the database root account and knew the password suggests either prior knowledge of the environment, credential reuse, or that the database root password was weak or default.

The dump was verified using `cat /tmp/patients_bigdump.csv`, which confirmed the file was a valid MariaDB 10.6.23 dump from localhost, database novameddb. The file contained two complete table dumps:

- patients — 35+ patient records including full names, dates of birth, phone numbers, diagnoses (e.g. Diabetes, Cardiac issues, Migraine), and insurance IDs (INS1001–INS2030+).
- staff_credentials — 13 staff records including usernames, bcrypt-hashed passwords, roles (admin, doctor, billing), full doctor names, specialties, salary figures, contact numbers, and hospital IDs (HOSP1001–HOSP1013).

The combined file weighed **7,891 bytes** and was written to `/tmp/` — a world-writable directory, deliberately chosen to avoid permission issues and reduce the need for privilege escalation at this stage.

5.3 Privilege Escalation

After exfiltrating the data, the attacker escalated to root using:

```
sudo -i
```

The ramyasoc account had sudo privileges, which allowed a full root shell without needing to exploit a vulnerability. This is a significant configuration issue — a standard user account with unrestricted sudo access dramatically lowers the cost of privilege escalation for any attacker who can log in.

5.4 Evidence Deletion — Anti-Forensics

Once at root, the attacker first confirmed the dump file was present:

```
ls -l /tmp/patients_bigdump.csv -rw-rw-r-- 1 ramyasoc ramyasoc 7891 Mar 28 20:18 /tmp/patients_bigdump.csv
```

Then, with a single command, they deleted it:

```
sudo rm /tmp/patients_bigdump.csv
```

The deletion of the dump file is a deliberate anti-forensics measure. The intent was to remove the local copy of the exfiltrated data so that anyone examining the system would find no evidence that a dump had taken place. However, the deletion of the file does not mean the data is gone — it was already exfiltrated before deletion. What the attacker removed was the local artefact, not the data itself. The data, at this point, is assumed to be in the attacker's possession.

It is also worth noting that `sudo rm` does not securely wipe file contents — it only removes the directory entry. With forensic tools, data recovery from unallocated disk sectors may still be possible, and filesystem journal entries may preserve traces of the file's existence.

6. Attack Timeline

The table below presents the complete reconstructed timeline of the attack, from the first login probe to the final deletion of evidence.

Timestamp	Actor	Action	Artefact / Detail
13:18:17 UTC	Attacker	SSH login attempt — FAILED	Target: root | Source: 192.168.110.145 | Rule 5503
13:18:42 UTC	Attacker	SSH login attempt — FAILED	Target: root | Source port: 49044 | Rule 5760
13:19:02 UTC	Attacker	SSH login — SUCCESS	Account: ramyasoc | Source port: 45574 | Rule 5715
13:19:02 UTC	System (PAM)	Login session opened	User: ramyasoc | Interactive shell established | Rule 5501
~13:19:05 UTC	Attacker	mysqldump executed	Cmd: mysqldump -u root -p novameddb > /tmp/patients_bigdump.csv
~13:19:10 UTC	Attacker	Dump verified	cat /tmp/patients_bigdump.csv — 7,891 bytes confirmed
~13:19:15 UTC	Attacker	Privilege escalation	sudo -i — root shell obtained
~13:19:20 UTC	Attacker	Evidence deletion	sudo rm /tmp/patients_bigdump.csv — dump file removed

7. MITRE ATT&CK Mapping

Technique ID	Name	Tactic	Observed Behaviour
T1110.001	Password Guessing	Credential Access	Two failed SSH login attempts against root account
T1078	Valid Accounts	Initial Access, Defence Evasion	Successful SSH login as ramyasoc using valid credentials
T1021.004	Remote Services: SSH	Lateral Movement	SSH used as the primary remote access vector
T1005	Data from Local System	Collection	mysqldump used to extract full database to local file

Technique ID	Name	Tactic	Observed Behaviour
T1567	Exfiltration Over Web Service	Exfiltration	Data dump staged in /tmp for likely transfer
T1548.003	Sudo and Sudo Caching	Privilege Escalation	sudo -i used to escalate from ramyasoc to root
T1070.004	File Deletion	Defence Evasion	sudo rm used to delete /tmp/patients_bigdump.csv

8. Impact Assessment

The impact of this incident spans both immediate data exposure and longer-term compliance risk. Two categories of sensitive data were compromised.

8.1 Patient Data (PHI)

The **patients** table contained at least 35 patient records. Each record included the patient's full name, date of birth, phone number, medical diagnosis, and insurance ID. This constitutes Protected Health Information (PHI) under applicable data protection regulations. The exposure of this data carries significant risk of patient harm through identity theft, insurance fraud, or targeted social engineering.

8.2 Staff Credentials

The **staff_credentials** table contained 13 records covering all hospital staff. While passwords were stored as bcrypt hashes rather than plaintext, the inclusion of usernames, roles, salary data, and hospital IDs means the attacker has a complete internal personnel map. Offline cracking of weak bcrypt hashes is also a realistic follow-on risk, particularly for accounts using simple passwords.

8.3 Regulatory Exposure

- PCI-DSS: Rules 5503, 5760 cite PCI-DSS 10.2.4 and 10.2.5 — failed and successful authentication logging requirements.
- HIPAA: Rule mappings cite 164.312.b — audit controls for systems containing electronic PHI.
- GDPR: Applicable under IV_35.7.d and IV_32.2, covering data protection impact assessments and security of processing.
- NIST 800-53: AU.14 (session audit) and AC.7 (unsuccessful login attempts) both triggered.

9. Recommendations

Immediate (Within 24 Hours)

- Rotate all credentials for the ramyasoc account and any account with sudo access on the affected host.
- Change the novameddb database root password immediately and audit all database user accounts.
- Isolate ramyasoc-virtual-machine from the network pending full forensic review.
- Notify affected patients and staff in accordance with your data breach notification obligations.
- Attempt file recovery of /tmp/patients_bigdump.csv using forensic tooling before any further writes to disk.

10. Conclusion

This was a focused, fast-moving attack. The attacker identified an SSH-exposed server, brute-forced access within two attempts, located and dumped a sensitive medical database, escalated privileges, and removed the only local evidence of the dump — all within approximately two minutes. The speed and precision of the operation suggest the attacker either had prior knowledge of the environment or conducted reconnaissance before this window.

Wazuh's alert chain provides a clear detection trail, but the absence of an active response meant the attacker was able to complete all post-access activity without interruption. The deletion of `/tmp/patients_bigdump.csv` is a standard anti-forensics technique and should not be mistaken for the data being destroyed — the exfiltration had already occurred before the file was removed.

The recommendations in Section 8 address the specific gaps exposed by this incident. Of these, **restricting SSH access**, **removing unrestricted sudo from standard accounts**, and **removing database root access from application-level operations** are the three changes most likely to prevent a recurrence of this exact attack chain.

Appendix — Attacker-Submitted Proof of Exploit

The following three screenshots were submitted by the threat actor as proof of successful exploitation. They confirm the exact tables accessed and the database they were extracted from. Their existence is consistent with an extortion or ransom scenario — the attacker is demonstrating they hold the data.

```
--
-- Dumping data for table `patients`
--

LOCK TABLES `patients` WRITE;
/*!40000 ALTER TABLE `patients` DISABLE KEYS */;
INSERT INTO `patients` VALUES (1,'Ravi Kumar','1985-06-15','1234-5678-9012','Diabetes','INS1001'),(2,'Meena Subramanian',
1003'),(4,'Priya Sharma','1995-12-05','4567-8901-2345','Migraine','INS1004'),(5,'Karthik Reddy','1988-07-18','5678-9012-3
mi Nair','1975-08-19','2222-3333-4444','Diabetes','INS2002'),(8,'Rajesh Kumar','1991-01-05','3333-4444-5555','Asthma','IN
6666-7777','Cardiac issues','INS2005'),(11,'Anita Desai','1985-09-30','6666-7777-8888','Thyroid','INS2006'),(12,'Vijay Si
INS2008'),(14,'Arvind Gupta','1983-03-25','9999-0000-1111','Hypertension','INS2009'),(15,'Kavita Joshi','1977-07-11','101
 Patil','1994-10-22','3030-4040-5050','Migraine','INS2012'),(18,'Rohit Agarwal','1981-01-29','4040-5050-6060','Cardiac is
03-13','6060-7070-8080','Fracture','INS2015'),(21,'Ankur Jain','1989-08-27','7070-8080-9090','Allergy','INS2016'),(22,'Sw
020','Diabetes','INS2018'),(24,'Megha Bansal','1991-09-07','1212-3434-5656','Asthma','INS2019'),(25,'Tarun Saxena','1987-
021'),(27,'Nitin Malhotra','1976-07-15','4545-6767-8989','Thyroid','INS2022'),(28,'Sonia Kapoor','1993-03-05','5656-7878-
','1990-01-25','7878-9090-1212','Hypertension','INS2025'),(31,'Pankaj Mehta','1982-06-30','8989-0101-2323','Diabetes','IN
3-4545','Migraine','INS2028'),(34,'Anjali Gupta','1988-05-03','1212-3434-5656','Cardiac issues','INS2029'),(35,'Rahul Kha
/*!40000 ALTER TABLE `patients` ENABLE KEYS */;
UNLOCK TABLES;
```

Exhibit A1 — Full dump of the patients *table from novameddb. Contains 35+ records: patient names, dates of birth, diagnoses, and insurance IDs. Sent by attacker as proof of data access.*

```
--
-- Dumping data for table `staff_credentials`
--

LOCK TABLES `staff_credentials` WRITE;
/*!40000 ALTER TABLE `staff_credentials` DISABLE KEYS */;
INSERT INTO `staff_credentials` VALUES (1,'admin','$2y$10$hashadmin','admin','Dr. Ravi Kumar','Cardiology',120000.00,'9876543210'
780','HOSP1002'),(3,'billing1','$2y$10$hashbill','billing','Dr. Arjun Nair','Pulmonology',110000.00,'9988776655','HOSP1003'),(4,'
sh5','doctor','Dr. Karthik Reddy','Orthopedics',125000.00,'9123456701','HOSP1005'),(6,'sneha','hash6','doctor','Dr. Sneha Iyer',
y',140000.00,'9345678923','HOSP1007'),(8,'anjali','hash8','doctor','Dr. Anjali Menon','Gynecology',115000.00,'9456789034','HOSP1
ha','hash10','doctor','Dr. Neha Kapoor','Oncology',150000.00,'9678901256','HOSP1010'),(11,'suresh','hash11','doctor','Dr. Suresh
',92000.00,'9890123478','HOSP1012'),(13,'manoj','hash13','doctor','Dr. Manoj Pillai','Nephrology',130000.00,'9901234589','HOSP101
/*!40000 ALTER TABLE `staff_credentials` ENABLE KEYS */;
UNLOCK TABLES;
/*!40103 SET TIME_ZONE=@OLD_TIME_ZONE */;
```

Exhibit A2 — Full dump of the staff_credentials *table. Contains usernames, bcrypt-hashed passwords, roles, salary figures, and hospital IDs for all 13 staff members. Sent by attacker as proof of credential access.*

```
ramyasoc@ramyasoc-virtual-machine:~$ cat /tmp/patients_bigdump.csv
/*M!999999\- enable the sandbox mode */
-- MariaDB dump 10.19  Distrib 10.6.23-MariaDB, for debian-linux-gnu (x86_64)
--
-- Host: localhost    Database: novameddb
-- ------------------------------------------------------
-- Server version       10.6.23-MariaDB-0ubuntu0.22.04.1
```

Exhibit A3 — Terminal output confirming the dump file /tmp/patients_bigdump.csv originated from novameddb *on MariaDB 10.6.23, localhost (ramyasoc-virtual-machine). Confirms the source database and server version.*

> **Analyst note:** These screenshots were provided directly by the attacker.

References

MITRE ATT&CK Framework

1. **T1110.001 — Brute Force: Password Guessing.**
   https://attack.mitre.org/techniques/T1110/001/
2. **T1078 — Valid Accounts.**
   https://attack.mitre.org/techniques/T1078/
3. **T1021.004 — Remote Services: SSH**
   https://attack.mitre.org/techniques/T1021/004/
4. **T1005 — Data from Local System.**
   https://attack.mitre.org/techniques/T1005/
5. **T1548.003 — Abuse Elevation: Sudo.**
   https://attack.mitre.org/techniques/T1548/003/
6. **T1070.004 — Indicator Removal: File Deletion.**
   https://attack.mitre.org/techniques/T1070/004/

Wazuh SIEM — Rule References

1. **Rule 5503 — PAM: User login failed.**
   https://documentation.wazuh.com/current/user-manual/ruleset/ruleset-xml-syntax/rules.html
2. **Rule 5715 — sshd: authentication success.**
   https://documentation.wazuh.com/current/user-manual/ruleset/ruleset-xml-syntax/rules.html
3. **Rule 5760 — sshd: authentication failed.**
   https://documentation.wazuh.com/current/user-manual/ruleset/ruleset-xml-syntax/rules.html
4. **Rule 5501 — PAM: Login session opened.**
   https://documentation.wazuh.com/current/user-manual/ruleset/ruleset-xml-syntax/rules.html

Regulatory & Compliance Frameworks

1. **NIST SP 800-61 Rev. 2.**
   https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf
2. **NIST SP 800-53 Rev. 5 — AU-14, AC-7.**
   https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final
3. **HIPAA Security Rule — 45 CFR § 164.312(b).**
   https://www.hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html
4. **GDPR — Articles 32 & 35.**
   https://gdpr-info.eu/art-32-gdpr/
5. **PCI-DSS v4.0 — Requirements 10.2.4 & 10.2.5**
   https://www.pcisecuritystandards.org/document_library/

Tools & Software

1. **OpenSSH.**
   https://www.openssh.com/
2. **MariaDB 10.6.23 — mysqldump.**
   https://mariadb.com/kb/en/mysqldump/
3. **Ubuntu 22.04.5 LTS.**
   https://ubuntu.com/about/release-cycle
4. **Kali Linux.**
   https://www.kali.org/
5. **Wazuh v4.x.**
   https://documentation.wazuh.com/